UNIT 1 · TOPIC 1.2

Suspicious Website Logins

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A student types a website address into their browser to log into their email. They notice the address bar shows "mail-gooogle-login.com" instead of the usual site. What is this an example of?

- ○ A. A normal website redirect for mobile users
- ○ B. A browser cache error
- **● C. A fake login page used to harvest credentials**
- ○ D. A VPN connection notice

Correct answer: C

Why: A misspelled or altered domain name designed to resemble a legitimate site is a classic sign of a fake login page (credential harvesting), built to trick users into entering their real credentials on an adversary-controlled site.

*Why the others are wrong: **A**, Students unfamiliar with domain structure may mistake a spoofed domain for a legitimate redirect. **B**, Students may assume any visual glitch is a technical error rather than a deliberate spoof. **D**, Students may confuse network-layer indicators with browser/address-bar indicators.*

2. Which of the following is the most reliable visual indicator that a login page may not be legitimate?

- ○ A. The page loads slowly
- **● B. The URL does not match the official domain of the service**
- ○ C. The page uses a dark color theme
- ○ D. The page asks for a username and password

Correct answer: B

Why: Every legitimate login page asks for a username and password, so that alone is not suspicious. The domain in the URL is the most dependable indicator, since adversaries cannot exactly replicate a verified domain name.

*Why the others are wrong: **A**, Page load speed depends on network conditions, not legitimacy. **C**, Visual styling can be copied easily and is not a security indicator. **D**, This is true of virtually all login pages, legitimate or not, so it has no diagnostic value.*

3. What term describes the practice of an adversary setting up a fraudulent website that mimics a real one in order to steal usernames and passwords?

- ○ A. Load balancing
- **● B. Credential harvesting**
- ○ C. Two-factor authentication
- ○ D. Data encryption

Correct answer: B

Why: Credential harvesting is the practice of collecting usernames and passwords, often via a fake login page designed to look identical to a trusted site.

*Why the others are wrong: **A**, This is an unrelated networking/infrastructure term. **C**, This is a defensive control, not an attack technique, students may confuse attack and defense vocabulary. **D**, Encryption protects data in transit/storage; it does not describe stealing credentials.*

4. A user reviews their account login history and finds entries from IP address 142.54.195.17 mixed in among entries from their usual IP address, 208.104.29.211, at times when they were in school and could not have logged in. What does this pattern most likely indicate?

- ○ A. The user logged in from a different device they forgot about

○ B. The internet service provider rotated the user's IP address automatically

○ C. The website is logging duplicate entries due to a software bug

● D. The account credentials have likely been compromised and used by an unauthorized party

Correct answer: D

Why: A login from a different IP address at a time the legitimate user could not have accessed the account is a strong behavioral indicator of unauthorized access, exactly how adversaries take advantage of weak or stolen authentication, surfacing in account activity logs.

*Why the others are wrong: **A**, This is plausible on its face but ignores the explicit detail that the user could not have logged in during school hours, which the scenario rules out. **B**, IP rotation by an ISP would not correlate specifically with times the user was unavailable, and wouldn't explain the pattern of access during school hours. **C**, This dismisses a real indicator as a technical artifact, a common but risky assumption.*

5. An adversary harvests a user's password from a fake login page and then successfully logs into three other unrelated services using the same credentials. Which weakness in user behavior did the adversary exploit?

○ A. Logging out after each session

○ B. Use of a strong, unique password

○ C. Enabling multi-factor authentication

● D. Password reuse across multiple accounts

Correct answer: D

Why: When users reuse the same password across multiple services, a single successful credential harvest gives an adversary access to every account that shares that password, a key reason weak authentication practices compound risk.

*Why the others are wrong: **A**, Logging out doesn't affect whether a stolen password works elsewhere. **B**, A unique strong password per site would have prevented this exact cross-account compromise, so it's the opposite of what happened. **C**, MFA would have blocked reuse-based access; students may not yet distinguish MFA from password strength.*

6. A user enters their credentials into a fake login page believing it is legitimate. Why does this technique succeed even against users who know phishing exists?

○ A. Because phishing only targets users with weak antivirus software

● B. Because the fake page is designed to be visually and structurally indistinguishable from the real one under quick inspection

○ C. Because browsers cannot detect any unencrypted website

○ D. Because the user's password was already publicly known

Correct answer: B

Why: Fake login pages exploit weak authentication indirectly by relying on visual deception, close replication of branding, layout, and URL similarity, so the attack succeeds on inattention rather than on the user's lack of awareness.

*Why the others are wrong: **A**, Antivirus software is not the relevant control here; this conflates malware defense with phishing defense. **C**, Encryption (HTTPS) indicates a secure connection, not a legitimate identity, a fake site can still use HTTPS, so this answer overstates what browsers can detect. **D**, This assumes a separate prior breach, which isn't implied by the scenario.*

7. A user's account login history shows consistent logins from one IP address on weekends and evenings, with two anomalous logins from a second IP address on a Wednesday and Monday, both during school hours. The user also reports that "some previous choices" in their account settings were changed without their knowledge. Which conclusion is best supported by the full body of evidence?

○ A. The anomalous logins are inconclusive on their own and the setting changes are unrelated, since settings can change due to app updates

● B. The pattern of anomalous timing, a distinct IP address, and unauthorized setting changes together indicate the account was accessed and modified by someone other than the user

○ C. The second IP address indicates the user logged in from a school computer, which explains both the timing and the setting changes

○ D. The evidence only proves a login occurred at an unusual time; it cannot indicate who performed the login

Correct answer: B

Why: Evaluating risk requires synthesizing multiple weak signals into a coherent judgment: anomalous timing alone is suggestive, a distinct IP strengthens it, and unauthorized setting changes corroborate it, together they support unauthorized access far more strongly than any single indicator would alone.

*Why the others are wrong: **A**, This under-weighs corroborating evidence by treating each indicator in isolation rather than synthesizing them, a common analytical error. **C**, This invents an explanation not supported by the data, the scenario states the user was in school, not logging in from school, and an app update wouldn't explain a new IP address. **D**, This is technically true of IP/timestamp data alone but ignores the corroborating setting-change evidence, making the conclusion incomplete rather than appropriately synthesized.*

8. A security analyst is asked to evaluate why credential-harvesting attacks remain effective despite widespread public awareness campaigns about phishing. Which explanation best reflects the underlying risk dynamic, rather than a surface-level cause?

○ A. Awareness campaigns fail because most users do not read them

● B. Awareness reduces but does not eliminate risk, because attackers continuously adapt visual and contextual cues faster than users adapt their scrutiny, and a single lapse is sufficient for compromise

○ C. Credential harvesting is only effective against older or less tech-literate users

○ D. Awareness is irrelevant because all credential theft happens through malware, not phishing pages

Correct answer: B

Why: This evaluates the risk at a systemic level: phishing is an asymmetric contest where the attacker only needs one successful deception, while the defender must maintain vigilance every time, explaining persistence of risk despite awareness, rather than attributing it to a single simplistic cause.

*Why the others are wrong: **A**, This is an unsupported generalization that oversimplifies a structural problem into a participation problem. **C**, This is a common but inaccurate stereotype; credential harvesting succeeds across age and experience levels due to its low margin for user error, not demographics. **D**, This incorrectly excludes phishing as a major credential-theft vector, contradicted by the topic's own focus on fake login pages.*

9. Two users have identical passwords stolen via the same credential-harvesting campaign. User X used that password on only one account; User Y reused it across five linked accounts. Evaluate the difference in resulting risk impact for each user.

○ A. Neither user faces meaningful risk if their passwords were "strong" at the time of theft

○ B. Both users face identical risk, since the same password was stolen from both

○ C. User X faces greater risk because having only one account makes that account a more obvious target

● D. User Y faces substantially greater impact because account linkage allows a single compromised credential to cascade into multiple account takeovers, while User X's exposure is contained to one account

Correct answer: D

Why: Risk impact depends not just on whether a credential is stolen, but on the blast radius enabled by reuse, this is the core reasoning behind why authentication hygiene (unique passwords per account) is emphasized as a mitigation in this topic's learning objectives.

*Why the others are wrong: **A**, Password strength is irrelevant once a password has already been harvested in plaintext or otherwise captured directly from a fake login page. **B**, This ignores that impact, not just initial exposure, is what differs, the theft event is the same but the consequence is not. **C**, This inverts the actual relationship between account count and blast radius.*

10. Which of the following is a security control that strengthens authentication beyond just a password?

● A. Multi-factor authentication (MFA)

○ B. Increasing the website's font size

○ C. Browsing in a private/incognito window

○ D. Clearing browser cookies daily

Correct answer: A

Why: Multi-factor authentication requires an additional verification step beyond a password, so even a stolen password alone is insufficient for an adversary to access the account.

*Why the others are wrong: **B**, This is a cosmetic/accessibility setting, unrelated to authentication strength. **C**, Private browsing affects local history storage, not account-side authentication. **D**, Clearing cookies affects session tracking on the local device, not the strength of the login process itself.*

11. What tool helps users avoid the risky practice of reusing the same password across multiple accounts?

○ A. A file compression utility

○ B. A pop-up blocker

○ C. A screen recorder

● D. A password manager

Correct answer: D

Why: A password manager generates and stores unique, complex passwords per account, removing the incentive to reuse passwords for convenience.

*Why the others are wrong: **A**, File compression is a storage utility with no authentication function. **B**, Pop-up blockers prevent unwanted browser windows, unrelated to password management. **C**, Screen recorders capture video, an unrelated tool category meant to test surface-level confusion.*

12. Before entering login credentials on a website, which security control can a user apply to verify the site's legitimacy?

○ A. Confirming the page loads in under one second

○ B. Confirming the page has a colorful logo

● C. Checking that the URL exactly matches the official domain

○ D. Confirming ads are displayed on the page

Correct answer: C

Why: Verifying the exact domain name against the known legitimate one is a practical, user-side control against credential harvesting via spoofed login pages.

*Why the others are wrong: **A**, Load time depends on network performance, not legitimacy. **B**, A logo is trivially copyable and provides no security assurance. **D**, Presence or absence of ads is unrelated to whether a site is the genuine one.*

13. A user's password was stolen via a fake login page, but the adversary was still unable to access the account because a one-time code from the user's phone was also required. Which control prevented account takeover in this case, and why?

● A. Multi-factor authentication, because it requires a second proof of identity that the adversary did not also obtain

○ B. Password complexity requirements, because the original password was strong

○ C. HTTPS encryption, because it hides the password from the adversary

○ D. A firewall, because it blocked the adversary's connection attempt

Correct answer: A

Why: MFA works precisely because it decouples successful login from possession of the password alone, even with the password harvested, the adversary lacked the second factor (the phone-based code).

*Why the others are wrong: **B**, The password was already harvested in full regardless of its strength, so complexity is not what stopped the adversary here. **C**, HTTPS protects data in transit but does not prevent a user from voluntarily entering a password into a fake page; it*

didn't "hide" anything from the page itself. ***D****, A firewall manages network traffic rules, not login authentication; this scenario describes an application-layer control.*

14. After noticing unfamiliar logins in their account history, a user wants to apply controls to prevent future unauthorized access. Which combination of actions best addresses the root cause of the compromise rather than just the symptom?

○ A. Change the account's display name to make it harder for the adversary to find

○ B. Log out of the current session and wait to see if the unfamiliar logins stop on their own

● C. Change the password to a new unique one and enable multi-factor authentication on the account

○ D. Delete the account activity log so the adversary cannot see when the user is online

Correct answer: C

Why: The root cause is a compromised credential; only changing the password (removing the adversary's existing access) combined with MFA (preventing future password-only access) addresses the cause, not just a visible symptom.

Why the others are wrong: ***A****, A display name change has no bearing on the adversary's ability to authenticate with the stolen credential.* ***B****, Passively waiting does not revoke the adversary's existing valid credential, the access remains until the password is changed.* ***D****, Deleting logs would actually remove the evidence needed to detect further unauthorized access, making the situation worse, not better.*

15. A school requires students to use a password manager and enable MFA on their accounts. Explain why requiring both controls together is more effective than requiring either one alone.

○ A. Both controls do the same thing, so requiring both is redundant but harmless

● B. A password manager reduces the chance of weak or reused passwords being harvested, while MFA limits the damage if a password is harvested anyway, the two controls address different points of failure

○ C. A password manager makes MFA unnecessary because it already generates secure passwords

○ D. MFA makes the password manager unnecessary because the second factor replaces the need for a password entirely

Correct answer: B

Why: Layered security controls are most effective when they cover different failure points: a password manager reduces the likelihood of credential exposure (prevention), while MFA reduces the impact if exposure happens anyway (containment), together they reduce risk more than either alone.

Why the others are wrong: ***A****, This conflates two controls that operate at different stages of the authentication process, missing the layered-defense reasoning.* ***C****, A strong password can still be harvested via a fake login page; MFA addresses exactly that residual risk.* ***D****, Most MFA implementations still require a primary password/credential as the first factor, they don't typically replace it entirely.*

16. A platform offers two MFA options: SMS-based one-time codes and an authenticator app generating time-based codes. Evaluate which option provides stronger protection against credential-harvesting-based account takeover, and why.

○ A. Both options are equally vulnerable, so the choice between them makes no practical difference

○ B. SMS-based codes are always stronger because they require physical possession of the phone itself

● C. The authenticator app is generally stronger, because SMS codes can be intercepted through SIM-swapping or number-porting attacks that don't require compromising the device itself

○ D. Neither option meaningfully improves security if the original password was already harvested

Correct answer: C

Why: A thorough evaluation of risk-management strategies requires weighing the specific failure modes of each control, SMS MFA has a documented attack surface (SIM swapping) that authenticator apps generally avoid, since the codes are generated locally on the device rather than transmitted over the telecom network.

Why the others are wrong: ***A****, This dismisses a real, well-documented difference in attack surface between the two control implementations.* ***B****, This overlooks that SMS can be redirected without the adversary ever possessing the physical device, undermining*

the assumption behind this answer. ***D****, This contradicts the entire premise of MFA as a mitigation, it directly addresses the scenario where the password has already been compromised.*

17. An organization is deciding between two policies: (1) mandatory password rotation every 30 days with no MFA, or (2) no forced rotation but mandatory MFA on all accounts. Evaluate which policy more effectively mitigates the risk demonstrated by credential-harvesting attacks.

○ A. Policy 1 is more effective, because frequent rotation guarantees that any harvested password will expire quickly

● B. Policy 2 is more effective, because frequent password rotation does not stop a freshly harvested password from being used immediately, while MFA blocks unauthorized access regardless of when the password was captured

○ C. The two policies are equivalent in effectiveness against credential harvesting

○ D. Policy 1 is more effective because it requires no additional device or app for users to manage

Correct answer: B

Why: This evaluates the timing mismatch in Policy 1: an adversary who harvests a password typically uses it within minutes or hours, well before a 30-day rotation cycle would invalidate it, so rotation does little against this specific threat, while MFA closes the gap regardless of timing.

Why the others are wrong: ***A****, This overstates rotation's effectiveness, it only helps against long-dormant breaches, not immediate post-harvest use, which is the realistic threat model here.* ***C****, This fails to account for the timing mismatch that makes one policy meaningfully weaker against this specific attack vector.* ***D****, This evaluates convenience rather than security effectiveness, missing the actual evaluation criterion the question asks about.*

18. A user wants to document the mitigation strategy they applied after discovering unauthorized logins on their account. Which documentation best captures both the immediate response and the layered prevention strategy, suitable for evaluating its effectiveness later?

○ A. "Told a friend about the suspicious activity"

○ B. "Logged out of the account"

● C. "Changed password to a unique, manager-generated one; enabled app-based MFA; reviewed account activity log for further anomalies after the change"

○ D. "Waited one week to see if the activity continued"

Correct answer: C

Why: Effective documentation of a mitigation strategy should capture both the corrective action (password change) and the layered preventive control (MFA), plus a verification step (reviewing the log afterward), this is what allows the effectiveness of the strategy to be evaluated later.

Why the others are wrong: ***A****, Informing a friend is not a technical mitigation and does not address the account's security state.* ***B****, Logging out does not revoke the adversary's valid credential and is not documented as a meaningful mitigation.* ***D****, Passive waiting is not a mitigation strategy and leaves the account vulnerable during the entire waiting period.*